

Task 9

Task Title: Man-in-the-Middle (MITM) Attack Using Ettercap

Date Completed: August 26, 2025

Target Environment: Local Virtual Network (Kali Linux + Ubuntu VM)

Tools Used:

- Kali Linux
 - Ettercap (Graphical)
 - Wireshark (for optional packet inspection)
-

Objective

The goal of this task was to perform a Man-in-the-Middle (MITM) attack using ARP spoofing to understand how attackers can intercept, monitor, or manipulate network traffic between two devices. This exercise also highlights the importance of encryption and secure communications protocols (e.g., HTTPS, SSL/TLS).

Setup & Procedure

1. Environment Setup:

- **Attacker:** Kali Linux VM
- **Victim:** Ubuntu 20.04 VM
- Both VMs were connected via a VirtualBox internal network to simulate a LAN environment.

2. Ettercap Installation & IP Forwarding:

- Ettercap was already available on Kali Linux. To ensure routing worked during the attack, IP forwarding was enabled:

```
echo 1 > /proc/sys/net/ipv4/ip_forward
```

3. Launching Ettercap (GUI):

- Ettercap was launched in graphical mode:

```
sudo ettercap -G
```

4. Sniffing Configuration:

- Chose **Unified Sniffing** and selected the active network interface (eth0).
- Performed a host scan to detect devices on the local network.
- From the **Hosts List**, selected:
 - **Target 1:** Victim IP (Ubuntu VM)
 - **Target 2:** Gateway IP (VirtualBox NAT adapter)

5. Initiating the MITM Attack:

- Selected **MITM > ARP Poisoning**
- Enabled "Sniff remote connections" and started the poisoning process.
- Began sniffing session and monitored captured traffic.

6. Traffic Observation:

- Used Ettercap's interface to observe intercepted traffic.
- Captured HTTP requests from the victim (example: visiting <http://neverssl.com>)
- Credentials sent over an unencrypted login form were visible.
- Verified packet details via Wireshark (optional step).

Findings

- Successfully intercepted unencrypted HTTP traffic between victim and gateway.
- Detected a plaintext username/password pair in an HTTP POST request.
- HTTPS traffic was encrypted and not viewable in Ettercap without SSL stripping.

- The attack highlighted how vulnerable devices become when using insecure protocols.
-

Learning Outcomes

- Understood the mechanics of **ARP spoofing** and how it redirects traffic through the attacker's machine.
 - Observed how easily **unencrypted credentials** can be stolen.
 - Learned the importance of **IP forwarding** to keep network communication functioning during MITM attacks.
 - Identified how **Wireshark** can complement MITM tools for packet-level analysis.
 - Recognized the role of HTTPS and VPNs in preventing such attacks.
-

Ethical Considerations

- This test was conducted in a **controlled and legal virtual environment**.
 - MITM attacks are illegal if performed without explicit permission.
 - Such techniques must only be used for **authorized penetration testing or security research**.
-

Recommendations for Defense

- Enforce **HTTPS-only** communication on web services.
 - Use **static ARP tables** or **dynamic ARP inspection** in sensitive networks.
 - Deploy **VPNs** to encrypt traffic on untrusted networks.
 - Implement **IDS/IPS solutions** to detect abnormal ARP traffic.
 - Educate users on avoiding public Wi-Fi for sensitive operations.
-

Interview Questions & Answers

1. What is a Man-in-the-Middle attack?

A MITM attack occurs when a malicious actor secretly intercepts or alters communication between two parties without their knowledge.

2. What is ARP spoofing?

ARP spoofing is a technique where an attacker sends fake ARP messages to a network, associating their MAC address with the IP address of another host (e.g., the gateway).

3. How can you detect a MITM attack?

Sudden ARP changes, duplicate IP warnings, or unexpected SSL certificate changes can be signs. Tools like `arpwatch` or IDS solutions can also help.

4. What tools are used for MITM attacks?

Ettercap, MITMf, Bettercap, Wireshark (for sniffing), and custom ARP spoofing scripts.

5. Why does HTTPS protect against MITM?

HTTPS encrypts data using SSL/TLS, preventing attackers from reading or modifying content even if traffic is intercepted.

6. What is the role of IP forwarding in MITM?

IP forwarding ensures that intercepted packets are relayed between the victim and gateway, keeping the communication uninterrupted while the attacker eavesdrops.

7. What are the legal and ethical concerns of sniffing traffic?

Unauthorized sniffing is a violation of privacy and computer laws. Ethical hackers must have permission and follow legal boundaries.

8. What are common signs of network compromise?

Unexpected SSL warnings, slow network speeds, duplicate IP conflicts, or firewall alerts may indicate an attack.

9. How does DNS spoofing relate to MITM?

DNS spoofing is a variant where an attacker redirects domain name resolutions to malicious IPs, facilitating MITM attacks.

10. How can organizations prevent MITM attacks?

Use encrypted protocols (HTTPS, SSH), implement strong network segmentation, use VPNs, and train staff on security awareness.